

S5L5: Analisi delle Minacce Cyber: Case Study OSINT e Spear-Phishing

Target Analysis: Ecosistema Finanziario SKKY Partners

1. Sintesi

Il presente rapporto analizza l'evoluzione delle metodologie di attacco mirato (Spear-Phishing) attraverso una simulazione didattica condotta contro l'assetto societario e di investimento del fondo di Private Equity **SKKY Partners**. Tramite tecniche di investigazione manuale a fontes aperte (OSINT), è stato possibile mappare l'infrastruttura difensiva dei canali di comunicazione istituzionali, identificare i nodi critici della catena di ricezione dei flussi finanziari e progettare uno scenario di attacco *Inbound* ad alta credibilità in grado di eludere i controlli euristici tradizionali dei sistemi di filtraggio.

2. Introduzione

La superficie di attacco delle organizzazioni finanziarie moderne si estende all'intero perimetro digitale e reputazionale dei suoi fondatori e dei partner di gestione. Nel settore del Private Equity, dove si analizzano quotidianamente capitali e transazioni ad alto valore, la cybersecurity rappresenta un pilastro strategico della continuità operativa. Questo documento dimostra come l'Information Harvesting avanzato consenta a un attaccante di raccogliere intelligenza operativa per colpire la linea di difesa umana (Investment Committee e Analyst) attraverso leve psicologiche basate sulla proposta di falsi accordi commerciali.

3. Panorama Attuale delle Minacce

3.1 Spear-Phishing Inbound e Ingegneria Sociale nel Private Equity

A differenza del phishing di massa, le varianti moderne destinate al settore finanziario utilizzano la tecnica dell'**Inbound Spear-Phishing**, invertendo il vettore di contatto. L'attaccante si presenta come un attore istituzionale legittimo (es. il colosso finanziario *Vanguard Group*) proponendo opportunità di business reali (Co-Investment Deals). Questo approccio disarma i filtri di sicurezza basati sull'analisi di parole chiave puramente minacciose o allarmistiche, poiché la valutazione di nuove proposte rientra nelle mansioni ordinarie del target.

3.2 Social Engineering Strutturale e Camouflage URL

L'uso di formati e-mail complessi consente l'integrazione di tecniche di occultamento avanzate:

- **Anchor Tag Spoofing:** Manipolazione del codice HTML per mostrare visivamente un URL sicuro e legittimo legato al fondo ([\(\[https://www.skky.com/\]\(https://www.skky.com/\)\)](https://www.skky.com/)), mentre l'attributo **href** instrada segretamente la vittima verso server di terze parti non autorizzati.
- **Typosquatting / Lookalike Domains:** Registrazione e utilizzo di domini specchio ingannevoli, come [skk1.com](https://www.skk1.com/), dove la sostituzione di caratteri omologhi (la lettera "y")

con il numero "1") sfrutta i limiti di visualizzazione dei dispositivi mobili e la disattenzione dell'operatore per simulare l'accesso a una finta stanza dati protetta.

4. Simulazione del Vettore di Attacco (Email Sample)

Al fine di validare le ipotesi di ricerca, viene documentato di seguito il modello (*sample*) di e-mail strutturato per la simulazione di Spear-Phishing, calibrato sui reali standard di comunicazione del settore Private Equity.

- **Mittente Simulato (Spoofed):** m.patorno@vanguard-investments.com
- **Target (Vittima):** info@skky.com (Investment Screening Team)
- **Oggetto:** Urgent: Co-Investment Opportunity & Joint CIM Review - Q3 2026 [Vanguard / SKKY]

 **Corpo del Messaggio (Formato HTML):**

Plaintext

5. Analisi delle Vulnerabilità Emergenti

5.1 Esposizione di Canali Funzionali (Public Records OSINT)

L'analisi OSINT condotta sui canali esposti del fondo ha evidenziato l'esistenza di caselle di posta funzionali (info@skky.com) destinate alla ricezione di documentazione esterna. Questi indirizzi rappresentano i punti di ingresso esatti per l'invio di Memorandum d'Investimento e due diligence finanziarie, canali costantemente monitorati dal personale amministrativo e dai consulenti associati al fondo.

5.2 Analisi Infrastrutturale Passiva (Reconnaissance)

Tramite l'utilizzo di piattaforme di intelligence visiva (**Maltego**), è stata mappata la topologia di rete del dominio principale skky.com, evidenziando:

- **Configurazione Record MX:** L'instradamento dei flussi e-mail aziendali su infrastrutture cloud avanzate. La conoscenza del server di posta consente la calibrazione di exploit specifici per analizzare i limiti di rilevamento dei filtri applicati a quella determinata suite aziendale.

6. Strategie di Difesa e Best Practices

6.1 Implementazione del Modello Zero Trust

Il principio "Mai fidarsi, verificare sempre" deve essere applicato rigidamente alle comunicazioni esterne nel settore degli investimenti. Ogni e-mail che richiede l'accesso a Virtual Data Rooms o lo scaricamento di allegati finanziari (come i file CIM o i Memorandum d'investimento) deve subire un processo di validazione fuori banda (Out-of-Band verification), verificando l'identità dell'analista mittente tramite canali alternativi confermati.

6.2 Rilevamento Avanzato del Typosquatting e Controlli Euristici

I sistemi di filtraggio e-mail aziendali devono integrare:

- **Algoritmi di Distanza di Stringa (Damerau-Levenshtein):** Per bloccare o mettere in quarantena automatica messaggi provenienti da domini con minime variazioni grafiche rispetto ai brand protetti del fondo o delle grandi istituzioni finanziarie partner.
- **Analisi dell'Età del Dominio (Domain Age Evaluation):** Respingerizzazione automatica di e-mail provenienti da domini registrati di recente (tipico delle infrastrutture usa-e-getta degli attaccanti).

6.3 Sanificazione degli Allegati (Content Disarm and Reconstruction - CDR)

L'adozione di tecnologie CDR permette di bloccare l'esecuzione di script o macro nascoste all'interno di file PDF o di link che forzano il download di file eseguibili camuffati, destrutturando l'oggetto e ricostruendolo in un formato statico e sicuro prima della consegna alla casella dell'Investment Committee.

7. Compliance e Framework Normativi

Il trattamento e la protezione dei canali di contatto aziendali all'interno di un fondo di private equity rispondono a precisi obblighi normativi:

- **DORA (Digital Operational Resilience Act):** Risulta direttamente applicabile qualora l'entità colpita (*SKKY Partners*) operi nel tessuto dei servizi finanziari, degli investimenti istituzionali o gestisca portafogli soggetti a regolazione, richiedendo test di penetrazione regolari basati su scenari di minaccia reali (TLPT) per valutare la resistenza dei dipendenti alle esche basate su manipolazione del codice HTML.

8. Conclusioni e Raccomandazioni

Il presente laboratorio dimostra che la tecnologia difensiva da sola non è sufficiente se non supportata da una costante formazione del personale (la "linea di difesa umana"). I manager di alto livello e gli analisti finanziari rappresentano i vettori d'accesso preferiti dalle minacce mirate per via dell'elevato volume di allegati che gestiscono quotidianamente. Si raccomanda lo sviluppo di sessioni di simulazione di Spear-Phishing periodiche per addestrare i team di gestione a riconoscere le anomalie di contesto e l'uso di tecniche di mascheramento degli URL durante l'analisi dei nuovi deal.